

## Priority Remediation Plan

1. Change and rotate the admin password; remove default credentials from docs and seed output.
2. Require 2FA for admin and moderator accounts before production launch.
3. Replace raw ad HTML with safe structured configuration or sandboxed iframe rendering.
4. Restrict article embeds to YouTube or sandbox all non-YouTube embeds with minimal permissions.
5. Fail startup when production security environment variables are missing or unsafe.
6. Fix public metadata leaks in OG images, series, polls, pinned profile articles, and notification hydration.
7. Make refresh-token rotation atomic and revoke sessions after security changes.
8. Add abuse limits to views, comments, reactions, follows, polls, and article-request endpoints.
9. Clean public/static folders and align robots.txt with backend rules.

## Production Launch Security Checklist

- NODE\_ENV=production
- HTTPS enforced at the proxy/CDN
- COOKIE\_SECURE=true
- COOKIE\_SAME\_SITE=lax or strict unless cross-site auth is required
- JWT\_SECRET and JWT\_REFRESH\_SECRET generated with high entropy and never committed
- TWO\_FACTOR\_ENCRYPTION\_KEY set separately from JWT secrets
- CAPTCHA\_REQUIRED=true and CAPTCHA\_SECRET configured
- TRUST\_PROXY correctly set behind the production reverse proxy
- Admin and moderator accounts protected by 2FA
- Database backups encrypted and access restricted to production operators only
- Centralized logs enabled for auth failures, admin actions, password resets, bans, and report status changes

## Audit Commands Used

Representative local checks used during the review:

- `npm audit --omit=dev`
- `rg "dangerouslySetInnerHTML|eval|localStorage|document.cookie|child_process|$queryRaw"`
- `rg "TODO|FIXME|backdoor|bypass|Admin@12345"`
- `find . -name ".env*" -print`